GRC103- RISK TREATMENT LAB

ZAINAB UMAR SHUAIBU

C11/26/CGRCE/17194

25/10/2026

Technical Risk Treatment Report: GRC103 Risk Assessment & Management Techniques

Organization: Northbridge Services

Role: GRC Analyst and Technical Control Implementer

Target Environment: Local Ubuntu Server 24.04 LTS (Isolated Network) & Kali Linux (Auditor/Testing Node)

Date: November 8, 2026

1. Executive Summary

As the GRC analyst and technical control implementer for Northbridge Services, a technical risk treatment assessment and hands-on hardening campaign were executed on our local internal document server running Ubuntu Server 24.04 LTS. The primary objective was to address legacy exposures, unrestrictive document directories, and network access vulnerabilities without interrupting the approved internal web portal (/public/).

Through this project, preventive, detective, and corrective controls were successfully implemented, validated, and documented using a Kali Linux testing node. Baseline evaluations indicated critical vulnerabilities, including an unauthenticated legacy service running on port 8080, open directory listings exposing dummy records, and unsegmented network access. Following the implementation of service retirement, directory restrictions, UFW firewall controls, and backup/restoration validation, the organization's overall risk profile was substantially lowered. This report outlines our technical findings, risk register transitions, four-strategy risk treatments (Avoidance, Mitigation, Transfer, and Acceptance), cost-benefit analyses, and ongoing operational monitoring requirements.

2. Baseline Environment and Risk Assessment

Baseline Configuration & Discovery

Using an isolated host-only network, the baseline environment was established with Ubuntu Server (192.168.56.20) and Kali Linux (192.168.56.10). Initial reconnaissance using Nmap and cURL confirmed the following baseline posture:

- **Port 80 (Nginx):** Active, hosting the approved internal portal alongside an open-listing archive directory containing training records.
- **Port 8080 (Python http.server):** Active, exposing an unnecessary legacy training endpoint (/srv/grc-legacy).
- **Directory Indexing:** Enabled on /, exposing raw file listings to any connected network client.

Baseline Risk Register (R1–R4)

Risks were evaluated using an ordinal scale (Likelihood 1–5, Impact 1–5; Score = Likelihood × Impact). Bands: 1–4 Low, 5–9 Medium, 10–16 High, 17–25 Critical.

ID	Asset	Threat Event	Observed Weakness	Likelihood	Impact	Score	Risk Band	Treatment Owner
R1	Legacy Endpoint Service (grc-legacy.service)	Unauthorized access or exploitation of legacy code/endpoints	Unnecessary Python HTTP server running on port 8080 with unauthenticated access	4	3	**12**	High	System Administrator
R2	Archive Directory (/var/www/grc-lab/archive/)	Unauthorized data exfiltration	Directory autoindex enabled and sensitive dummy records published directly under web root	4	4	**16**	High	Data Protection Officer
R3	Internal Document Server Network Interface	Unauthorized lateral movement or reconnaissance	No host-based firewall restrictions; any host on the subnet can reach ports 80 and 8080	3	4	**12**	High	Network Security Lead

R4	Portal Content (/var/www/grc-lab/public/)	Loss of availability or data integrity	Single-point-of-failure web directory with no local backup or recovery testing verification	2	3	**6**	Medium	IT Operations

3. Technical Risk Treatment Implementation

Step 1: Applying Avoidance to the Legacy Workflow (R1)

To address **R1**, the unnecessary legacy service was retired via service termination and disabling, eliminating the attack surface on port 8080 while keeping the approved port 80 service intact.

- **Proposed Change:** Retire unused legacy Python HTTP server endpoint (grc-legacy.service).
- **Business Impact:** Zero impact on approved business operations; removes extraneous code and listening ports.
- **Approval Role:** GRC Change Control Board (*Simulated*).
- **Rollback Procedure:** sudo systemctl enable --now grc-legacy.

Execution Commands & Verification:

Bash

```
None
sudo systemctl disable --now grc-legacy
sudo systemctl is-active grc-legacy
sudo ss -lntp
```

- **Post-Treatment Validation:** Nmap scans from Kali confirmed port 8080 was closed/filtered, while port 80 remained fully accessible. This avoids the retired workflow's exposure but does not eliminate risks inherent to the remaining active web service.

Step 2: Implementing Preventive Controls — Removing Archive Publication (R2)

To resolve **R2**, the archive folder was relocated outside the web root, file permissions were restricted to root only, and Nginx configurations were updated to disable autoindex and explicitly deny access to the old path.

Execution Commands:

Bash

```
None
sudo mkdir -p /srv/grc-private
sudo mv /var/www/grc-lab/archive /srv/grc-private/
sudo chmod -R go-rwx /srv/grc-private/
```

Nginx Configuration Update (/etc/nginx/sites-available/grc-lab):

Nginx

```
None
server {
    listen 80;
    server_name _;
    root /var/www/grc-lab;
    access_log /var/log/nginx/grc_access.log combined;
    error_log /var/log/nginx/grc_error.log;

    location / {
        autoindex off;
    }
    location /archive/ {
        deny all;
    }
}
```

- **Validation:** Testing from Kali confirmed that /public/ returned HTTP 200, whereas /archive/ and direct requests to /archive/dummy-records.txt returned HTTP 403 Forbidden. Note that disabling directory listings alone prevents browsing, but explicit access denial (deny all) or moving files outside the web root is required to prevent direct-file retrieval if filenames are guessed.

Step 3: Restricting Network Access with UFW (R3)

To mitigate network-layer exposure (R3), Ubuntu's Uncomplicated Firewall (UFW) was configured to enforce a default-deny inbound posture, allowing traffic to port 80 exclusively from the authorized Kali testing IP (192.168.56.10).

Execution Commands on Ubuntu:

Bash

```
None
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from 192.168.56.10 to any port 80 proto tcp
sudo ufw logging on
sudo ufw enable
sudo ufw status numbered
```

Blocked-Source Verification Test from Kali:

Bash

```
None
sudo ip addr add 192.168.56.11/24 dev eth0
curl --interface 192.168.56.11 --connect-timeout 5
"http://192.168.56.20/public/"
sudo ip addr del 192.168.56.11/24 dev eth0
```

- **Result:** Unapproved source 192.168.56.11 experienced a connection timeout and failed to reach the web portal. UFW logging confirmed drops on incoming packets from unauthorized IPs.

Step 4: Verification of Detection and Recovery (R4)

Log Correlation

Requests from the approved Kali address to /public/ and /archive/ were correlated against Ubuntu system logs:

- Nginx access logs recorded successful HTTP 200 requests for /public/ and HTTP 403 responses for /archive/.
- Kernel / UFW logs (sudo journalctl -k / /var/log/ufw.log) recorded explicit [UFW BLOCK] events for unauthorized probing from secondary test interfaces, proving that firewall-blocked traffic was dropped at the network layer before reaching the Nginx application layer.

Backup and Verified Restoration Exercise

To establish resilience against data loss (R4), a secure local backup workflow was tested:

1. Created a restricted backup directory (/srv/grc-backups, permissions 700).
2. Generated a tarball archive and SHA-256 integrity hash of the original portal:
3. Bash

```
None
sudo tar -czpf /srv/grc-backups/public-before-test.tgz -C
/var/www/grc-lab public
```

```
sha256sum /var/www/grc-lab/public/index.html | tee
~/portal-before.sha256
```

4.
5. Simulating data loss, the index file was removed (sudo rm /var/www/grc-lab/public/index.html), confirming service failure from Kali.
6. Performed restoration:
7. Bash

```
None
sudo tar -xzpf /srv/grc-backups/public-before-test.tgz -C
/var/www/grc-lab
sha256sum -c ~/portal-before.sha256
```

8.
9. **Outcome:** Hash verification succeeded (OK), and Kali re-verification confirmed HTTP 200 with original content restored. Observed recovery time was under 60 seconds. *Note: While local same-host backups validate restoration mechanics, they do not protect against total host hardware failure or hypervisor compromise.*

5. Evaluation of Decision Strategies & Financial Reasoning

Model Transfer and Acceptance

- **Transfer Exercise (Option B Evaluation):** Evaluated a managed-backup offer priced at $120 setup plus $20/month.
    - *Provider Duties:* Automated daily snapshot storage, infrastructure uptime, and off-site replication.
    - *Retained Customer Duties:* Periodic restoration testing, integrity verification, and access credential management.
    - *Service Limitations:* Does not indemnify against application-layer logical corruption or misconfiguration. (No contract was executed; modeled for decision comparison).
- **Acceptance Exercise:** Plain HTTP was temporarily accepted for this isolated lab environment containing *dummy training data only*, under strict operational conditions:
    - *Owner:* GRC Lead / IT Operations.
    - *Residual Risk Score:* 4 (Low).
    - *Rationale:* Isolated host-only network with no external internet routing; non-sensitive dummy records.
    - *Expiry & Triggers:* 14-day formal expiry. Mandatory re-evaluation and immediate treatment upgrade (TLS deployment) triggered if real data, external network connectivity, or broader user access is introduced. Approved under a *simulated* governance waiver.

Cost Analysis and Quantitative Risk Modeling

First-Year Cost Options

- **Option A (Hardening Work):** 4 hours lab labor @ $25/hour + $50 annual maintenance = **$150** first-year cost.
- **Option B (Managed Backup):** $120 setup + (20 × 12 months = $240) recurring = **$360** first-year cost.
- **Option C (TLS Deployment):** 3 hours labor @ $25/hour + $25 annual maintenance = **$100** first-year cost.
- *Selected Combination:* Options A + C (Internal Hardening & TLS) for foundational security, supplemented by local verified backups. Excluded costs include unquantified administrative overhead and third-party auditing fees.

Illustrative Backup ALE / Benefit Model (Option B Scenario)

(Note: The following figures are purely illustrative risk assumptions for financial modeling methodology; recovery tests do not establish dollar values, and ordinal risk scores are not converted into monetary savings.)

- **Annual Occurrence Rate (AOR):** 0.2 (estimated 1 event every 5 years).
- **Single Loss Expectancy (SLE) - Baseline:** $5,000 per data loss event.
- **Baseline Annual Loss Expectancy (ALE):** $\text{AOR} \times \text{SLE} = 0.2 \times \$5,000 = \$1,000$.
- **Tested Control Mitigation:** Tested recovery control assumed to reduce post-event loss to 1,000.
- **Residual ALE:** $0.2 \times \$1,000 = \$200$.
- **Annual Benefit (Risk Reduction):** $\text{Baseline ALE} - \text{Residual ALE} = \$1,000 - \$200 = \$800$.
- **First-Year Net Benefit:** $\text{Annual Benefit} - \text{First-Year Cost (Option B: } \$360\text{)} = \$800 - \$360 = \mathbf{\$440}$.

6. Post-Treatment Risk Register Reassessment

Following control implementation and validation, risks R1 through R4 were reassessed to measure residual exposure:

ID	Asset	Threat Event	Treatment Applied	Residual Likelihood	Residual Impact	Residual Score	Residual Band	Review Trigger
R1	Legacy Endpoint Service	Unauthorized exploitation	Avoidance: Service disabled & purged from	1	3	**3**	Low	Quarterly configuration audit

			runlevels					
R2	Archive Directory	Unauthorized data exfiltration	Mitigation: Relocated to /srv/grc-private/, autoindex off, deny all	1	3	**3**	Low	Web structure change request
R3	Server Network Interface	Unauthorized network probing	Preventive Control: UFW strict source IP whitelisting	1	3	**3**	Low	Subnet or IP topology change
R4	Portal Content Availability	Loss of service / data loss	Corrective Control: Verified backup & tested restoration runbook	2	2	**4**	Low	Monthly backup restoration test

7. Monitoring and Operational Handover

To maintain posture and detect configuration drift post-implementation, the following operational checks are established:

1. **Approved Portal Availability:**
    - *Owner:* IT Operations
    - *Frequency:* Hourly automated check (HTTP 200 status code verification)
    - *Threshold:* Failure > 2 consecutive checks
    - *Escalation:* Paging alert to Systems Administrator
2. **Unexpected Open Ports (Drift Check for Retired Service):**
    - *Owner:* Security Operations
    - *Frequency:* Daily automated Nmap scan against localhost/subnet
    - *Threshold:* Any listening port other than 80/22
    - *Escalation:* Immediate incident ticket creation and service audit
3. **Recovery-Test Success Validation:**
    - *Owner:* GRC Compliance Analyst
    - *Frequency:* Monthly
    - *Threshold:* Unsuccessful hash verification or recovery time > 15 minutes
    - *Escalation:* Management review meeting and backup script remediation